RETOUR D'EXPÉRIENCE · OCTOBRE 2026

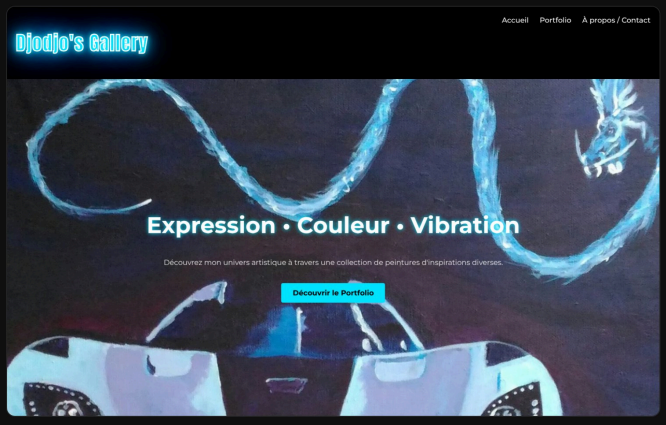
Djodjo's Gallery

STREET ART & TECHNOCULTURE

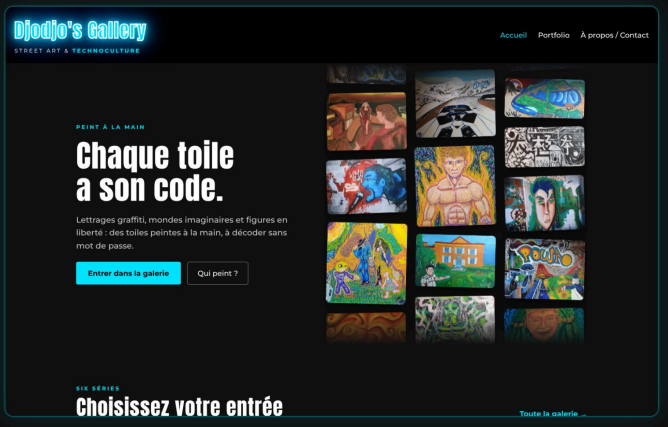
Refondre et sécuriser un site vitrine en seize jours, avec une IA

De fichiers déposés à la main à un site versionné, déployé automatiquement, durci et relu : 79 pull requests, des captures avant/après et les leçons tirées.

AVANT · 2 OCTOBRE



APRÈS · 6 OCTOBRE



Geoffroy, alias Djodjo
En reconversion vers la cybersécurité (blue team)

Site : djos-galley.online
Développé avec Claude (IA)

Sommaire

En bref 3

Qui a fait quoi 4

La méthode 4

Six temps 6

- Fondations · 28 septembre – 2 octobre 6
- Refonte · 3 octobre 6
- Durcissement · 5 octobre 9
- Visibilité et revue de code · 5 – 6 octobre 11
- Formulaire et finitions · 7 – 8 octobre 13
- Livre d'or et mentions légales · 8 – 13 octobre 13

Incidents et leçons 15

Réflexes cyber appliqués 17

La suite 18

Annexe : les 79 pull requests 20

À propos de ce document

Ce retour d'expérience couvre la création et la refonte de mon site, du 28 septembre au 13 octobre 2026 (PR #1 à #79). Il est écrit pour des recruteurs : ce qui a été fait, par qui, avec quelles méthodes, et ce que les erreurs m'ont appris.

Le code du site est dans un dépôt privé : les numéros de pull request servent de repères, et l'annexe les liste toutes. Les captures « avant » sont rendues depuis l'historique Git, avec les mêmes polices et la même taille d'écran que les captures « après ».

Une version en ligne de ce document est publiée sur mon GitHub.

En bref

Djodjo's Gallery est le site vitrine de mes peintures : street art, lettrages graffiti, personnages, machines. Il ne vend rien. Il me sert aussi de terrain d'entraînement pour ma reconversion vers la cybersécurité.

Du 28 septembre au 13 octobre 2026, le site est passé de fichiers déposés à la main chez l'hébergeur à un projet versionné, déployé automatiquement, durci et relu. Le travail tient en **79 pull requests**, que j'ai toutes relues avant de les fusionner ou de les fermer. Dix-sept viennent du workflow d'ajout de toiles, deux de Dependabot ; les 60 autres ont été préparées avec **Claude (IA)**, l'assistant d'Anthropic.

Indicateur	Avant	Après
Œuvres en ligne	10, sans classement	66, en six séries
Ajouter une toile	modifier le HTML à la main	déposer une photo, relire une pull request
Poids des images de départ (11 fichiers)	18,9 Mo	4,4 Mo (−77 %)
Galerie sur téléphone (33 toiles)	13,1 Mo	2,4 Mo (−82 %)
En-têtes de sécurité HTTP	0	6, HSTS d'une semaine, version de PHP masquée
Ressources chargées chez un tiers	Google Fonts sur chaque page	aucune
Accessibilité	toiles hors d'atteinte au clavier, formulaire sans étiquettes	0 problème détecté par l'outil axe sur les 4 pages
Adresses du site	`www` et adresse principale servies en double	une seule adresse (`301`), page 404 du site
Erreurs dans la galerie (3 octobre)	3 doublons, 1 image cassée	0
Titre principal (`h1`)	le logo, sur les trois pages	un par page, propre à chaque page

Ce que le projet m'a fait pratiquer : Git et GitHub (branches, pull requests, relecture), GitHub Actions, sécurité web (CSP, HSTS, en-têtes HTTP), sécurité de la chaîne d'approvisionnement, fuites d'information (OWASP WSTG), RGPD et pseudonymisation (HMAC), divulgation coordonnée (`security.txt`), accessibilité (axe, navigation au clavier), référencement (Search Console, redirections), lecture des en-têtes avec `curl`, règles Apache (`.htaccess`), travail encadré avec une IA.

> Le code du site est dans un dépôt privé. Les numéros de pull request (PR) servent de repères ; l'annexe les liste toutes.

Qui a fait quoi

Le pied de page du site dit « conçu, codé et sécurisé par Djodjo et Claude (IA) ». Voici le partage réel.

Moi (Geoffroy)	Claude (IA)
Objectifs, priorités et direction artistique	Trois revues de code complètes, diagnostics
L'idée de « Street art & technoculture », le nom des séries Horizons et Électrons libres	Propositions d'en-tête, maquettes de l'accueil, premiers jets des textes
Le choix de la maquette, la correction et la validation de tous les textes	Le code : HTML, CSS, JavaScript, PHP, Python, workflow GitHub Actions
La création du dépôt et sa liaison avec l'hébergeur	Les tests avant chaque PR : navigateur automatisé (ordinateur et téléphone), Apache local, outil d'accessibilité axe
La relecture et la fusion de chaque pull request	La rédaction des pull requests et de `CLAUDE.md`
Les vérifications sur le site en ligne (`curl`, console du navigateur) et Search Console, propriété vérifiée par DNS	Le diagnostic de ce que Google montrait, à partir de ces vérifications
Les photos et les titres des toiles, les décisions de consentement, le choix des descriptions Google et de l'image de partage	L'explication de chaque choix et de chaque erreur, les miennes comme les siennes
La série Persos, créée seul sans aide au code ; l'en-tête HSTS, trouvé moi-même en exercice guidé	La correction du formulaire de contact (PR #64), testée sur un serveur PHP local
La mesure de l'adresse IP réelle des visiteurs, en exercice guidé ; la clé secrète du formulaire, générée et installée par moi	La page « Sous le capot » et son fichier `security.txt` (PR #69 et #70)
La validation des textes de « Sous le capot », et ce qu'elle ne doit jamais dire	
Le choix de la modération a priori du livre d'or, du menu, du lien dans la bio et de rester sous pseudonyme	Le livre d'or, ses tests d'abus, la page de mentions légales (PR #72 et #75)
Les décisions sur la durée de conservation des messages et sur les coordonnées de l'hébergeur	La relecture des mentions légales face au code, et la correction d'une promesse trop ferme (PR #79)

La méthode

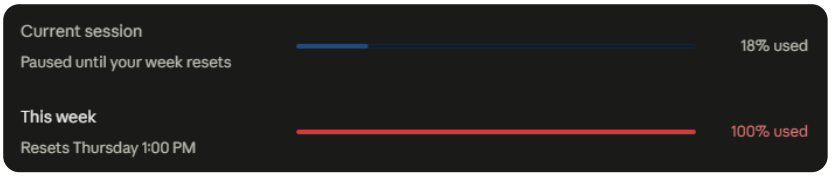
1. **Diagnostiquer d'abord** : le code, les textes et les toiles sont relus avant toute proposition.
2. **Montrer avant de coder** : maquettes avec les vraies toiles, captures avant chaque changement visuel.

3. **Écrire les textes à part** : rédigés et validés dans un document partagé, puis intégrés en une seule PR.
4. **Une branche et une pull request par sujet**, testée sur ordinateur et sur téléphone.
5. **Un humain fusionne** : Claude n'a jamais poussé sur la branche principale.
6. **Vérifier en ligne après la fusion** : codes de réponse et en-têtes avec `curl -I`, console du navigateur, Search Console. L'IA travaille dans un environnement isolé qui ne joint pas le site : ces vérifications passent par moi.

`CLAUDE.md`, la mémoire du projet. Ce fichier, dans le dépôt, décrit les conventions et les règles de sécurité : aucun secret dans le dépôt, aucune ressource chargée chez un tiers, contraintes de la politique de sécurité du contenu, commentaires publics sans détails internes, tests à faire avant chaque PR. L'IA le relit à chaque session : les garde-fous sont écrits une fois, au lieu d'être répétés à chaque conversation. Depuis le 8 octobre, il impose aussi un suivi : chaque action de Claude est notée au fil de la tâche dans le résumé de l'état du site, et Claude demande à la fin de chaque tâche si ce dossier doit être mis à jour.

Travailler avec une IA, sans lui donner les clés. Claude n'accède qu'au dépôt du site, sur autorisation, et ne fusionne rien. Ses propositions passent par la même relecture que n'importe quelle contribution. Ses erreurs figurent dans le tableau des incidents : c'est la relecture qui les a rattrapées.

L'IA n'est pas illimitée. Claude s'utilise avec une limite d'usage hebdomadaire. J'ai épuisé la mienne en six jours : le 7 octobre après-midi, la jauge était à 100 %, et je n'ai plus eu accès à Claude avant sa remise à zéro, le lendemain à 13 h. C'était une erreur de ma part. J'ai mené en parallèle deux très longues conversations en réflexion étendue, un mode où Claude réfléchit plus longtemps avant de répondre, et consomme donc beaucoup plus. Je l'avais activé dans la première, et la seconde l'a gardé par défaut sans que je m'en aperçoive. Le contenu y a gagné en qualité, mais la limite a fondu. Depuis, je vérifie ce réglage à l'ouverture de chaque conversation. J'ai aussi gardé trois habitudes : une conversation par sujet, un résumé de l'état du site pour reprendre ailleurs sans tout relire, et des captures recadrées.



Ce que l'IA change pour moi. J'ai découvert l'IA avec Claude, et c'est un compagnon de travail remarquable. En une semaine, j'ai fait ce qui m'aurait pris, selon mon estimation, deux mois à plein temps. Mais produire avec une IA est un travail en soi : il faut formuler, relire et vérifier. L'IA a aussi un revers : je codais moins moi-même, et j'avais l'impression de pouvoir m'en tirer avec quelques notions. Vu la vitesse à laquelle Claude écrit et teste du code, apprendre à coder m'a même paru inaccessible, et presque obsolète. C'est un piège quand on vise la cybersécurité, où il faut comprendre ce qu'on défend : le but n'est pas d'écrire aussi vite qu'une IA, mais de savoir lire et juger ce qu'elle écrit. J'ai donc gardé des exercices à faire seul, avec un simple indice : l'en-tête HSTS, puis l'adresse IP réelle des visiteurs du formulaire.

Six temps



1. Fondations (28 septembre - 2 octobre, PR #1 à #14)

Un dépôt et un déploiement sûrs. Le dépôt GitHub est privé : le site reste public, mais le code, l'historique et une éventuelle erreur de commit ne le sont pas. L'hébergeur est relié par OAuth à ce seul dépôt, pas au compte entier, et redéploie le site à chaque fusion sur la branche principale. Le formulaire de contact lit ses identifiants dans un fichier placé hors de la racine web, et aucun fichier privé n'est suivi par Git.

`CLAUDE.md` (PR #5) : voir « La méthode ».

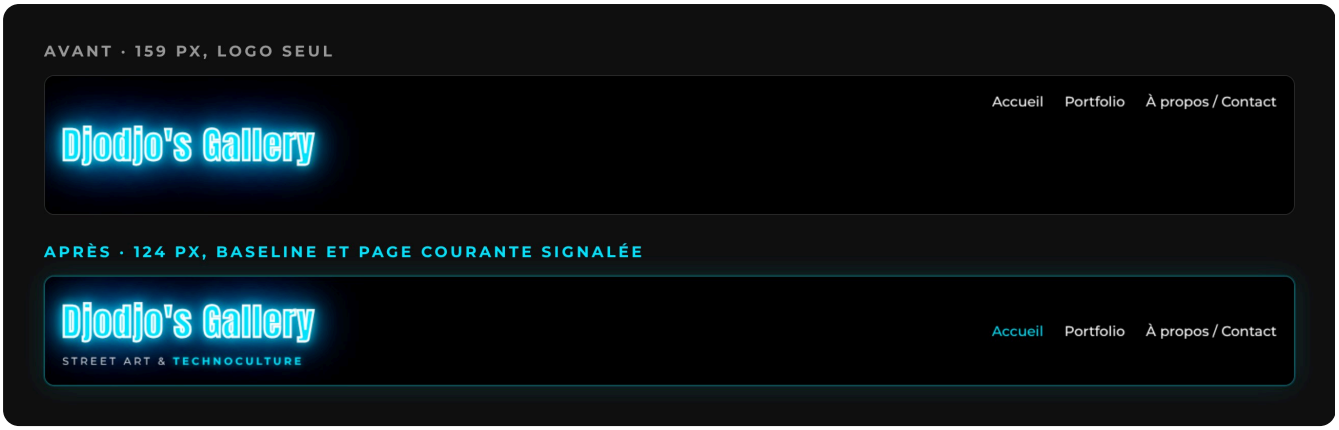
Première revue de code (PR #6 à #11) :

- galerie cassée sur les téléphones de moins de 370 px de large : le script calculait zéro colonne et empilait toutes les toiles ;
- images allégées de 18,9 à 4,4 Mo, sans différence visible ;
- page par défaut de l'hébergeur supprimée ;
- code tiers et fichiers cachés bloqués côté serveur, liste des dossiers désactivée, trois premiers en-têtes de sécurité ;
- formulaire de contact protégé par un champ piège anti-robots et une limite d'envois.

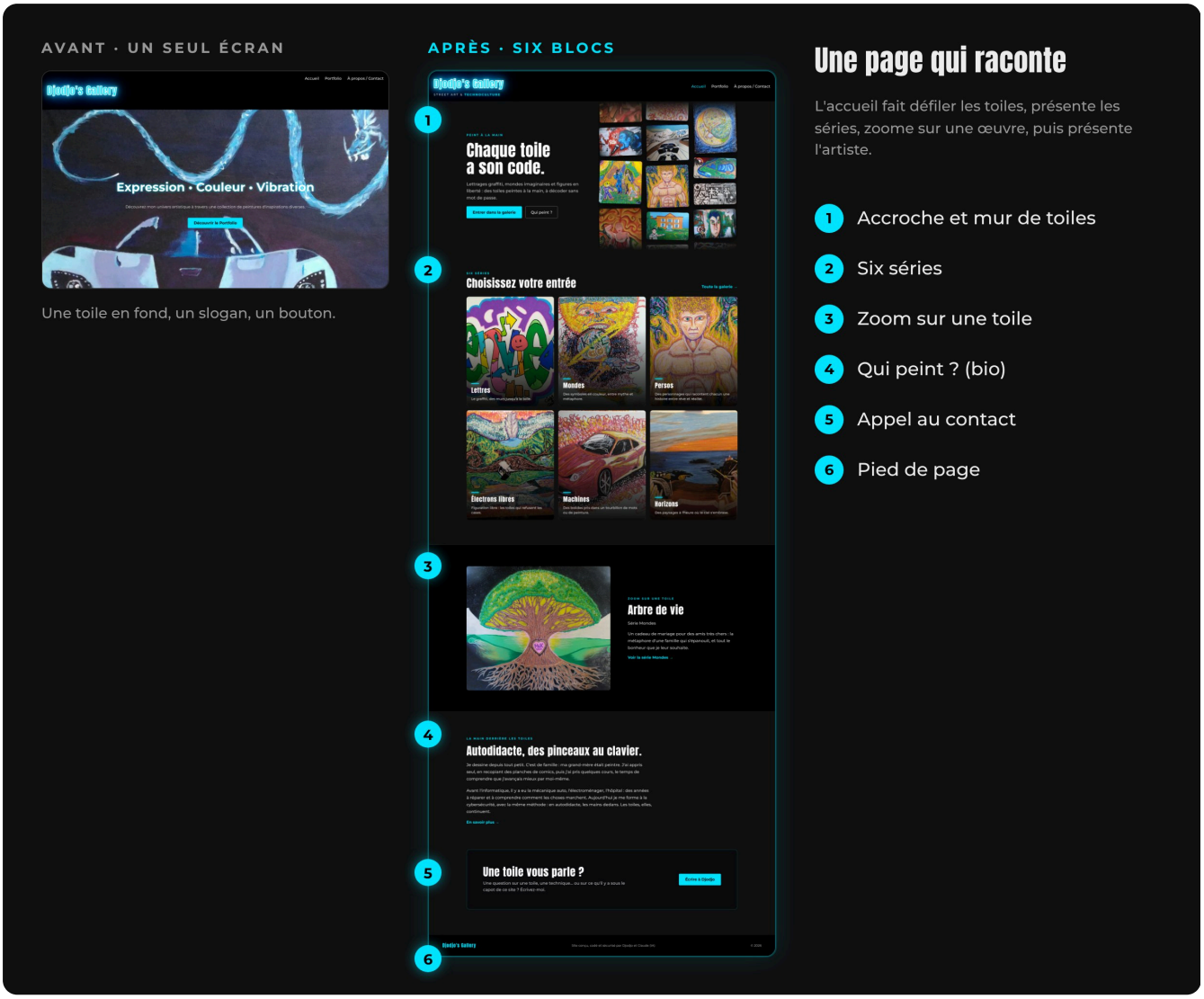
Le workflow d'ajout de toiles (PR #12). Ajouter une toile demandait de modifier le HTML à la main. Une galerie listée automatiquement en PHP a été envisagée ; j'ai préféré garder un site statique et un humain avant chaque publication. Une photo déposée dans un dossier déclenche un workflow GitHub Actions, qui la traite et ouvre une pull request.

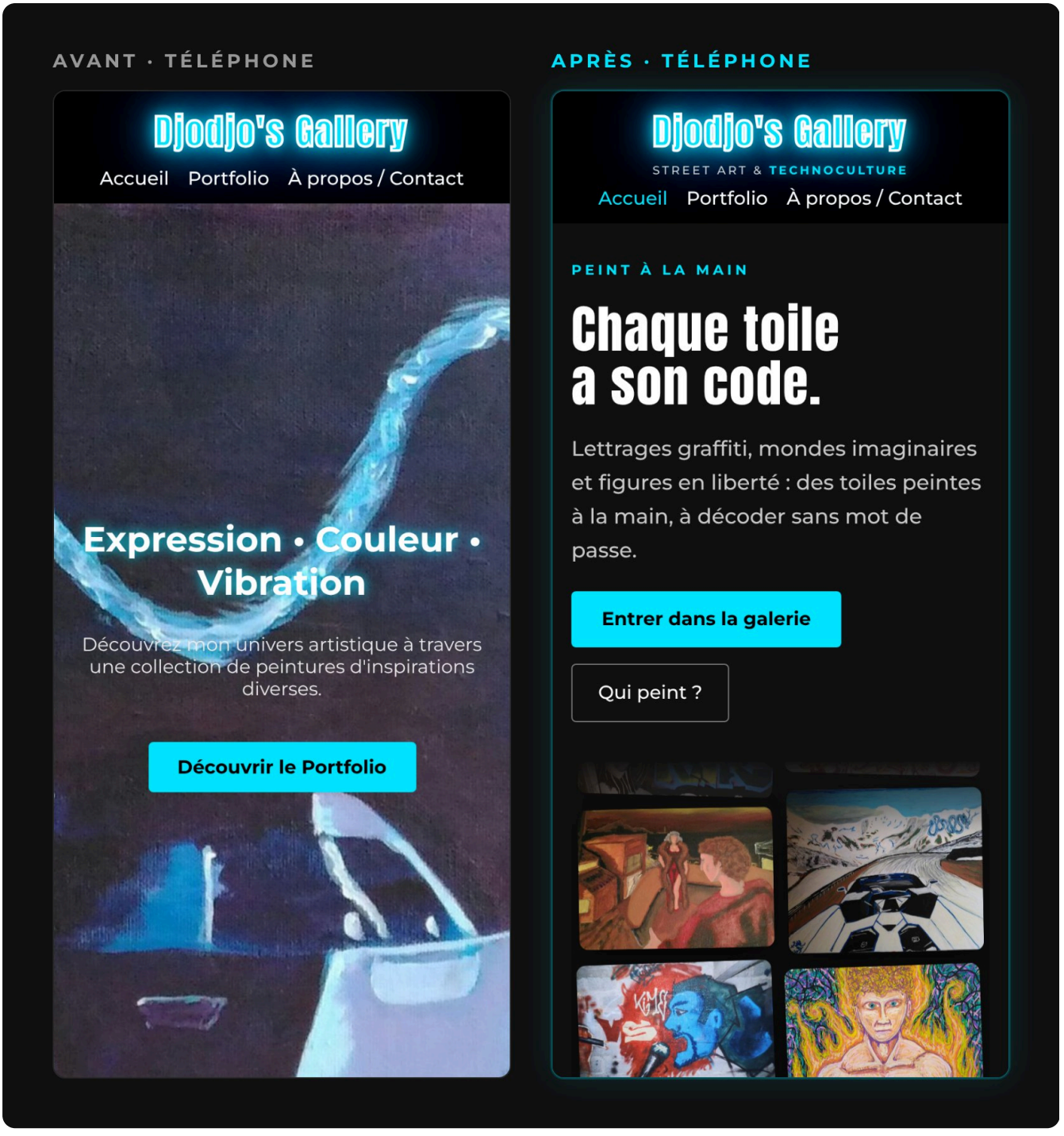
2. Refonte (3 octobre, PR #15 à #36)

L'en-tête (PR #19). « Artiste peintre » est un intitulé de métier, et la peinture n'est pas le métier que je vise. « Street art & technoculture » décrit le travail : le mot parle à la fois des machines peintes et de la carrière tech. Il s'écrit en un seul mot et en minuscule : avec un espace, on lirait « culture techno », la musique.

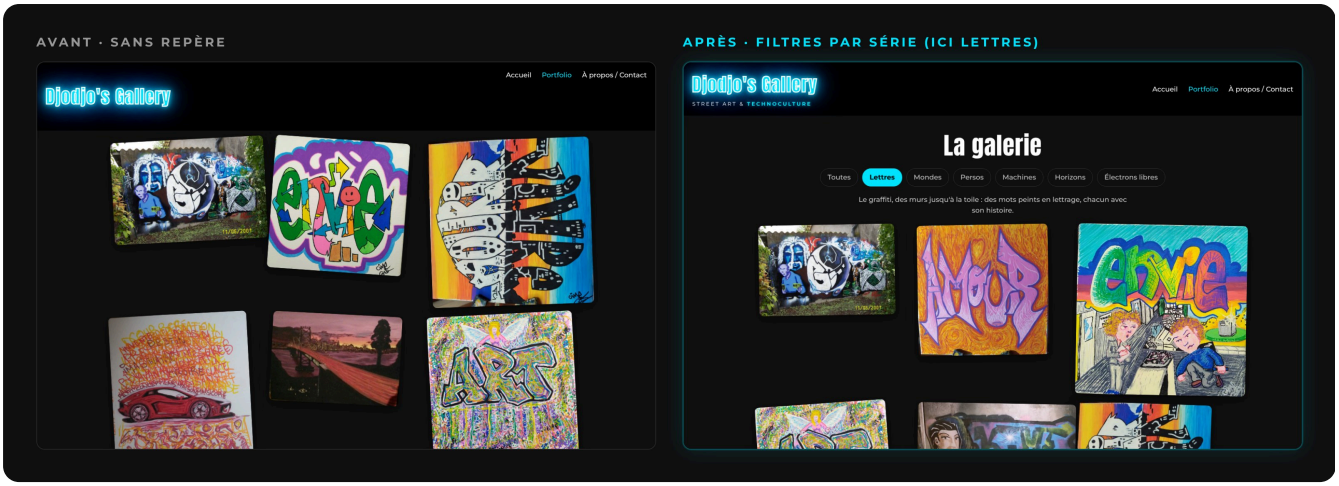


L'accueil (PR #24 à #27). D'une bannière fixe à une page qui raconte : l'accroche « Chaque toile a son code. », un mur de toiles qui défilent, les cartes des séries, un zoom sur une toile, la bio, le contact. Les voitures restent au second plan, et aucun nombre de toiles n'est affiché, car il deviendrait faux à chaque ajout.

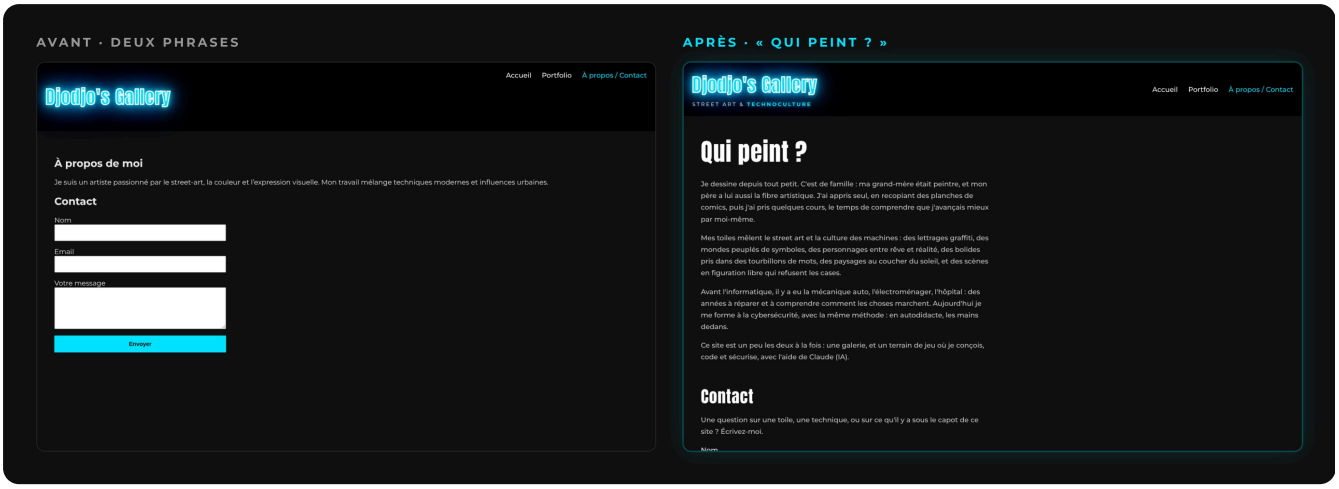




Les séries (PR #22 et #23). Six séries, chacune avec son filtre et sa propre adresse (`portfolio.html#mondes`). La série est portée par le HTML de chaque toile, et la liste des séries n'existe qu'à un seul endroit, que le workflow relit : une série s'ajoute sans toucher au code. Je l'ai vérifié en créant seul la série Persos.



Les textes (PR #36). Tous réécrits dans un document partagé, corrigés et validés, puis intégrés en une seule PR : un `h1` par page, une phrase par série, une description pour Google par page, et pour chaque toile une description de ce qu'on voit, distincte de son titre.

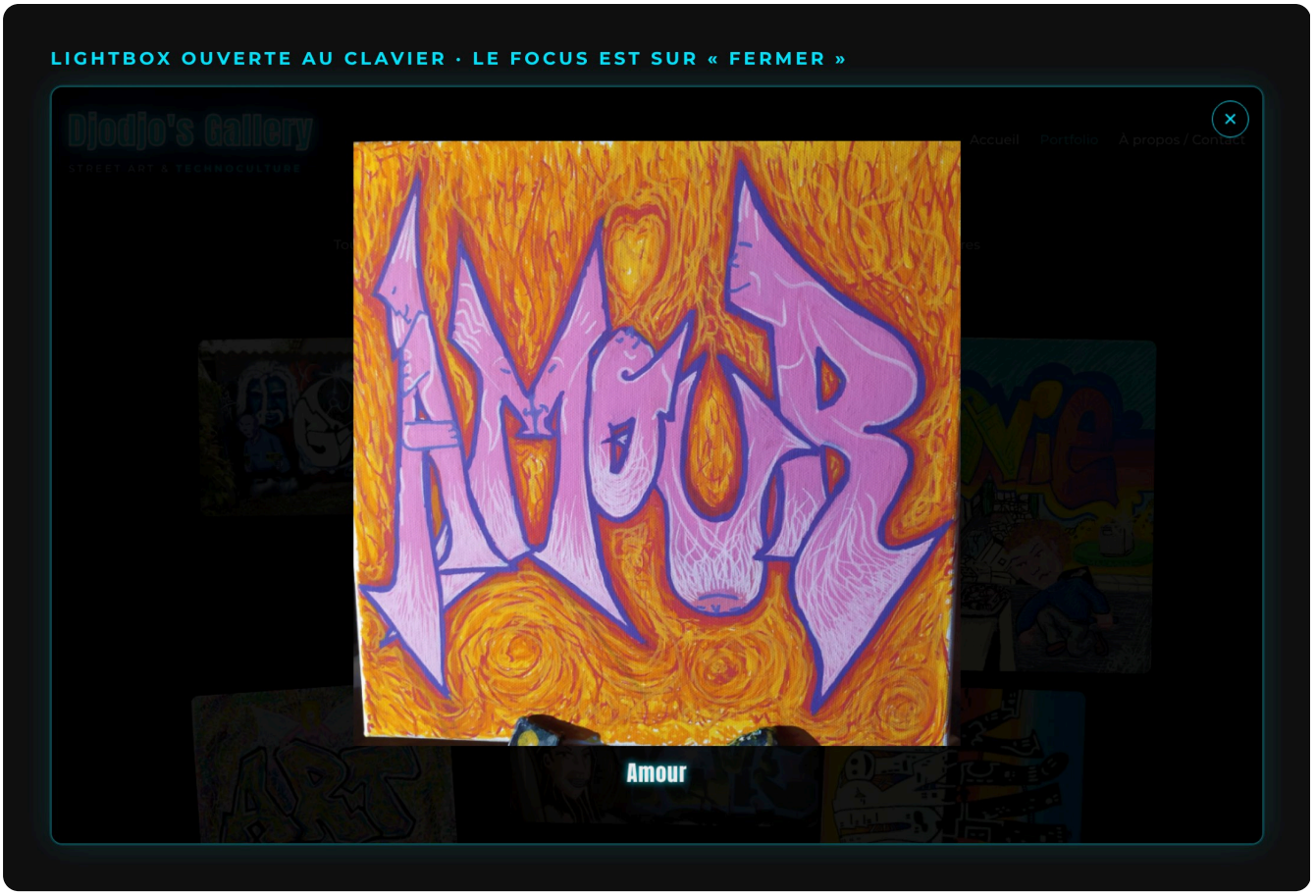


Le chargement (PR #29 à #31). Des miniatures de 640 px avec `srcset` : le navigateur prend la plus petite image qui suffit. Les pages HTML sont revérifiées à chaque visite (`Cache-Control: no-cache`).

3. Durcissement (5 octobre, PR #37 à #49)

Données personnelles (RGPD) (PR #37). Les polices venaient de Google Fonts : chaque visite envoyait l'adresse IP du visiteur à Google, sans son accord. Elles sont maintenant servies par le site. Plus aucune ressource n'est chargée chez un tiers, et `CLAUDE.md` l'interdit pour la suite.

Accessibilité (PR #38). L'outil axe et des tests au clavier ont révélé trois problèmes : la touche Tab sautait toutes les toiles, la visionneuse n'avait pas de bouton de fermeture, et les champs du formulaire n'avaient pas d'étiquette. Chaque toile est maintenant un bouton, et la visionneuse est une vraie fenêtre de dialogue. Le focus va sur « Fermer », reste dans la fenêtre, puis revient sur la toile à la fermeture. Au passage, une adresse mal formée qui cassait la galerie retombe maintenant sur « toutes les séries ».



En-têtes de sécurité (PR #39). Une politique de sécurité du contenu stricte : la page ne charge que des fichiers du site lui-même, et un script injecté serait bloqué par le navigateur. S'y ajoutent `Permissions-Policy`, qui refuse caméra, micro et position, et le retrait de `X-Powered-By`, qui annonçait la version de PHP.

HSTS, par paliers (PR #40). Cet en-tête oblige le navigateur à rester en HTTPS. Mal réglé, il peut rendre un site inaccessible pendant toute sa durée. Il a donc commencé à 60 secondes, est passé à une semaine le 6 octobre (PR #54), et s'allongera encore par paliers (un mois, puis un an), avec une vérification à chaque étape. J'ai trouvé la ligne moi-même, en exercice guidé.

Workflow sécurisé (PR #41, #42 et #49). Le workflow ouvre des fichiers venus de l'extérieur et peut écrire dans le dépôt : il méritait le même soin qu'un serveur. Les actions sont désignées par l'empreinte d'un commit plutôt que par une étiquette déplaçable, les modules Python sont vérifiés par empreinte, et Dependabot propose les mises à jour, que je relis avant de fusionner (PR #49). Le jeton d'écriture n'est donné qu'à la dernière étape. La PR #41, ouverte exprès puis fermée, a prouvé en conditions réelles que ce jeton limité suffisait.

Remplacer une toile sans piège de cache (PR #48). Une image remplacée sous le même nom peut rester ancienne pendant une semaine chez les visiteurs, à cause du cache de l'hébergeur. Le workflow remplace maintenant une toile sous un nouveau nom, et met à jour la galerie et l'accueil.

Le même jour, 25 toiles ont rejoint la galerie (PR #43 et #46).

4. Visibilité et revue de code (5 - 6 octobre, PR #50 à #63)

Partage et référencement (PR #50 et #51). Un lien du site collé dans WhatsApp, LinkedIn ou Discord affiche maintenant un aperçu : titre, description et image (balises Open Graph). Chaque page déclare son adresse de référence (`canonical`), et le site a ses icônes, des données structurées pour Google, un `robots.txt` et un `sitemap.xml`. Sur ordinateur, WhatsApp ne montre qu'une vignette carrée découpée au centre de l'image : la composition est donc symétrique, le logo au milieu, et les quatre toiles entrent dans ce carré. J'ai choisi cette version parmi plusieurs variantes.



Ce que Google montrait encore (PR #54 et #55). Une recherche « djos gallery » affichait toujours l'ancien titre « Artiste Peintre – Accueil ». Le diagnostic, fait avec `curl -I` et Search Console : l'adresse `www` et l'adresse principale répondaient toutes les deux `200` avec la même page, et Google gardait une vieille copie de la version `www`. La balise `canonical` n'est qu'une suggestion ; une redirection `301` de `www` vers l'adresse principale est un ordre. La même PR ajoute une vraie page 404, qui garde son code d'erreur (sinon Google croirait que l'adresse existe), et passe HSTS à une semaine. Le passage de `http` à `https` est déjà fait par le CDN de l'hébergeur : une règle de plus dans `.htaccess` aurait pu faire tourner le site en boucle. Enfin, les descriptions commencent maintenant par « street art », les mots qu'on cherche vraiment.



Ce que le site disait de lui-même (PR #52 et #53). Tout le monde peut lire les fichiers publics, et `robots.txt` est souvent le premier qu'on ouvre pour reconnaître un site (OWASP WSTG-INFO-03). Son commentaire citait les dossiers internes, alors qu'il disait justement ne pas les citer (erreur de Claude, dans la PR #50). Les commentaires du HTML et du CSS nommaient le fichier de règles du projet, le workflow et la protection du formulaire. Ce n'étaient pas des failles, puisque ces dossiers répondent `403`, mais des informations gratuites. Tout est retiré, et `CLAUDE.md` pose la règle : les commentaires publics expliquent la mise en page, jamais l'intérieur du site.

Troisième revue de code (PR #56 et #58). Tout le code a été relu, sauf le code tiers. Voici ce qui a été corrigé.

- **`.htaccess` en défaillance ouverte** (PR #56). Les protections étaient rangées dans des blocs `<IfModule>` : si un module manque, Apache ignore ces règles sans rien dire. Démonstration sur un Apache local, sans le module de réécriture : des fichiers internes répondaient `200`, et le contrôle de syntaxe répondait « Syntax OK ». Hors de ces blocs, un module manquant donne une erreur 500 visible, et rien ne fuit. Vérifié en ligne le 6 octobre : les pages répondent normalement, et les fichiers internes `403`.
- **Le jeton d'écriture n'est plus sur la machine qui ouvre les photos** (PR #58). Le workflow tourne désormais en deux jobs, sur deux machines. Le premier traite les photos avec un jeton en lecture seule. Le second ne lance ni Python ni la bibliothèque d'images : il contrôle le résultat du premier (fichiers autorisés seulement, aucun lien symbolique ni fichier exécutable), puis ouvre la pull request. Au passage, les liens symboliques sont refusés : un lien vers une image déjà en ligne était accepté comme une nouvelle toile.
- **Le code tiers suivi** (PR #58). Le formulaire de contact s'appuie sur une bibliothèque d'envoi de mails, et rien ne surveillait sa version. Un fichier de verrouillage décrit maintenant exactement la version installée.

Les autres points concernaient le formulaire de contact : ils sont traités par la PR #64, au cinquième temps. Ce document ne décrit que des points corrigés : on ne publie pas une faiblesse encore ouverte.



Le nouveau workflow a été testé sur une branche jetable (PR #57, fermée), puis en conditions réelles : les quatre dépôts de photos suivants (PR #60 à #63) sont passés par les deux jobs sans erreur. La galerie compte maintenant 62 œuvres, dont plusieurs graffitis sur mur.

403 plutôt que 404. Faut-il cacher les dossiers internes derrière une erreur 404, pour ne pas confirmer qu'ils existent ? La réponse reste 403 : le gain serait de l'obscurité, pas de la protection. Et côté blue team, une 403 sur un dossier interne, dans les journaux du serveur, est un signal clair de reconnaissance, qui se noierait parmi les liens cassés.

5. Formulaire et finitions (7 - 8 octobre, PR #64 à #70)

Le formulaire de contact, en exercice guidé (PR #64). La revue de code soupçonnait la limite d'envois de compter la mauvaise adresse, à cause du CDN de l'hébergeur. Claude m'a donné un indice plutôt que la réponse, et j'ai mesuré : une ligne de journal temporaire, un envoi depuis le PC puis depuis le téléphone en 4G, et une comparaison avec `ifconfig.me`. Verdict : l'hypothèse était fausse. Mais la mesure a révélé un autre point, corrigé dans la même PR.

J'ai aussi travaillé sur la façon dont le formulaire garde la trace des adresses des visiteurs. Une empreinte sans clé n'est pas anonyme : avec 4,3 milliards d'adresses IPv4 possibles, on retrouve l'adresse d'origine en quelques minutes. C'est une pseudonymisation, pas une anonymisation. Mon premier essai ajoutait un sel aléatoire à chaque envoi, ce qui empêchait de reconnaître deux envois du même visiteur. Un sel protège des mots de passe ; ici, il fallait une clé fixe et secrète (HMAC). Après deux autres essais, j'ai demandé à Claude d'écrire la correction, que j'ai relue. Le formulaire garde désormais des empreintes à clé secrète, générée sur mon poste sans jamais s'afficher à l'écran, et les efface rapidement. Il refuse les envois venus d'un autre site, et s'arrête proprement si sa configuration est incomplète, au lieu de fonctionner sans protection.

Après la fusion, j'ai vérifié en ligne qu'un envoi venu d'un autre domaine était refusé et qu'un vrai message passait. J'ai aussi vidé le journal PHP des lignes qui contenaient mes adresses IP en clair : le test avait laissé des données personnelles derrière lui.

Les dernières toiles (PR #65 à #67). Quatre toiles de plus : la galerie en compte 66. Les dix plus récentes avaient pour description leur seul titre, faute de mieux : un lecteur d'écran lisait « fresque-1 ». Claude a écrit les dix descriptions après avoir regardé les toiles, et j'ai choisi cinq nouveaux titres à la place de ceux qui ressemblaient à des noms de fichiers.

Le pied de page partout (PR #68). La mention « conçu, codé et sécurisé par Djodjo et Claude (IA) » figure maintenant sur toutes les pages, pas seulement sur l'accueil.

Sous le capot (PR #69 et #70). Une nouvelle page, d'abord dans le menu (elle est passée dans le pied de page le 12 octobre, voir le temps 6), explique aux visiteurs comment le site les protège : ce que reçoit leur navigateur, le formulaire de contact, leur vie privée, la façon dont le site est construit, et comment signaler une faille. Elle s'en tient aux principes, jamais aux réglages : aucun seuil, aucune durée, aucun nom de fichier interne ni d'outil. C'est la règle de ce dossier : tout ce qu'une page publique dit, un attaquant le lit aussi. Un fichier `security.txt` (norme RFC 9116) indique aux chercheurs en sécurité où signaler une faille. La page renvoie vers ce retour d'expérience par un simple lien : rien n'est chargé chez GitHub avant le clic. Le menu passe à quatre liens, réglés pour tenir sur une seule ligne dès 360 px de large.

6. Livre d'or et mentions légales (8 - 13 octobre, PR #71 à #79)

Une règle de suivi (PR #71). Chaque action de Claude sur le projet est notée au fil de la tâche, et Claude demande à la fin de chaque tâche si ce retour d'expérience doit être mis à jour. C'est la réponse à l'incident du 8 octobre.

Le livre d'or, finalement codé par Claude (PR #72). J'avais prévu de l'écrire moi-même, avec Claude en relecteur. Faute de temps, j'ai changé d'avis : Claude l'a codé en m'expliquant chaque étape, et j'ai relu.

Ce choix change le partage du travail, et je le dis ici plutôt que de laisser croire le contraire. Le principe tient en trois points :

- **Rien n'est publié automatiquement et rien n'est stocké sur le serveur.** Un message validé par le serveur m'arrive par e-mail, avec la ligne prête à ajouter dans un fichier de messages ; je la publie par une pull request, comme n'importe quel changement. Les autres sont supprimés. Cette modération a priori m'évite une page d'administration à protéger (authentification, protection contre les requêtes forgées, limite de tentatives) et des données personnelles à garder.
- **Un message est du texte, jamais du code.** Pour qu'un visiteur ne puisse pas faire exécuter un script aux autres (faille de type XSS stockée), la page n'écrit jamais un message comme du HTML. Le fichier des messages en contient un par ligne : une ligne cassée est ignorée sans casser les autres, ce qui compte quand on le modifie à la main.
- **Le serveur ne fait pas confiance au navigateur.** Il vérifie lui-même les longueurs, refuse les caractères invisibles ou qui inversent le sens de lecture, les liens et les adresses e-mail, et limite les envois, par visiteur et pour tout le site (sans cette seconde limite, mille adresses différentes noieraient ma boîte de réception). Il reprend les protections du formulaire de contact.

Le code commun aux deux formulaires a été regroupé dans un seul fichier, pour qu'un correctif vaille pour les deux : le comportement du contact a été comparé avant et après sur la même batterie de tests, avec des résultats identiques. Avant la fusion, Claude a joué une trentaine de cas d'abus (messages trop longs, données du mauvais type, caractères piégés, envois en rafale) et vérifié dans un navigateur qu'un message contenant du code s'affiche comme du texte. Ces tests ont trouvé **un vrai défaut de l'ancien formulaire de contact** : un champ envoyé sous forme de liste provoquait une erreur fatale côté serveur. Corrigé dans la même PR : il répond maintenant comme à un champ vide.

Le menu (PR #72). Le livre d'or remplace « Sous le capot » dans le menu, qui garde quatre liens ; « Sous le capot » passe dans le pied de page. Claude avait d'abord annoncé un menu à cinq liens, alors que les règles du projet exigent une seule ligne dès 360 px : c'est moi qui ai tranché.

Faire remarquer la page déplacée (PR #75). Une page de sécurité reléguée dans le pied de page est moins vue d'un recruteur. J'ai choisi le moyen le plus discret : dans la bio, le mot « sécurise » est devenu un lien vers « Sous le capot ».

Mentions légales (PR #75). Je ne vends rien et je publie sous un pseudonyme. La loi autorise alors un éditeur non professionnel à rester anonyme, à condition que son hébergeur connaisse son identité et que la page nomme l'hébergeur et donne ses coordonnées. La page explique aussi, sans réglages, ce qui est fait des données du formulaire de contact, du livre d'or et de l'adresse IP, annonce l'absence de cookies et rappelle mes droits.

Les règles de travail (PR #77). Après les erreurs de la journée, j'ai fait écrire dans `CLAUDE.md` trois choses : mettre à jour l'état du site à la fin de chaque session, lire l'état réel des PR sur GitHub avant d'en parler, et suivre une feuille de route pour mettre à jour ce document. Elle est suivie de pièges de session : pas de PR empilées, pas de réécriture de branche sans vérifier, pas de serveur de test laissé au premier plan. La PR #78 a corrigé cette feuille de route, qui envoyait écrire la mise à jour au mauvais endroit (voir les incidents).

Relire la page de mentions légales face au code (PR #79). Le 13 octobre, en réponse à ma question sur les obligations d'un pied de page, Claude a relu la page de mentions légales en la comparant au code des deux formulaires. Trois sujets en sont sortis.

- **Des informations manquaient.** Pour chaque donnée laissée par un visiteur, la page dit maintenant pourquoi elle est traitée et sur quel fondement (répondre à une demande, le consentement pour le livre d'or, l'intérêt légitime de limiter le spam), qui la reçoit (l'hébergeur, comme sous-traitant), combien de temps elle est gardée, et quels droits on peut exercer (accès, rectification, effacement, opposition, limitation, retrait du consentement). Elle prévient aussi qu'un message publié dans le livre d'or est public et peut être indexé par les moteurs de recherche. J'ai fixé la durée de conservation des messages de contact au plus court, et la page dit que je n'en tire aucun fichier de clientèle ni liste de diffusion.
- **Une promesse était plus ferme que le code.** La page décrivait l'effacement des empreintes d'adresses en termes plus fermes que le code. Claude l'avait écrite sans la vérifier contre le code ; la relecture l'a vu. Je n'ai pas changé le code : j'ai corrigé les textes (la page de mentions, la page « Sous le capot », `CLAUDE.md`) pour qu'ils disent ce que le code fait.
- **Les coordonnées de l'hébergeur.** La loi demande un téléphone ; l'hébergeur n'en publie pas pour l'entité qui héberge mon site. Je n'ai pas inventé de numéro : la page affiche le numéro officiel que le groupe publie, et dit d'où il vient. Il me reste à trier ma messagerie pour tenir la durée de conservation annoncée.

Incidents et leçons

Incident	Cause	Ce que j'en retiens
Une image remplacée revient dans son ancienne version (28 septembre, puis 5 octobre)	Même nom de fichier ; le cache de l'hébergeur garde l'image une semaine	La leçon du premier jour avait été oubliée. Le workflow l'applique maintenant (PR #48)
Doublons et image cassée dans la galerie	J'ai écarté la correction prête dans la PR #18 pour réparer à la main, directement sur la branche principale	Une correction relue et testée vaut mieux qu'une réparation à la main. Le fichier, sa miniature et sa ligne vont ensemble
Des prénoms publiés dans un texte de l'accueil	PR fusionnée sans relecture	Retirés à la PR suivante, six minutes plus tard, mais une publication ne s'efface jamais complètement. Relire avant de fusionner ; ne publier que le nécessaire
Deux toiles représentant des personnes réelles, titrées par leur prénom ou surnom	Publiées avant d'avoir l'accord des personnes	L'une retirée, l'autre renommée. Utiliser le portrait de quelqu'un demande son accord ; publier est irréversible
Une PR décrivait un comportement faux (erreur de Claude)	Description non vérifiée	Corrigé par la PR #16 : relire aussi ce que l'IA affirme
Deux correctifs sur téléphone sans effet (erreur de Claude)	Corrections sur hypothèse, sans mesure sur l'appareil	Problème encore ouvert : mesurer avant de corriger

Incident	Cause	Ce que j'en retiens
Maquettes perdues dans l'éditeur (erreur de Claude)	Une réorganisation a fait planter l'outil	Toujours fournir une version image d'une maquette
Conflits de fusion en série	Mon éditeur reformatait tout le fichier à chaque sauvegarde	Formater quand on le décide ; récupérer la dernière version avant de modifier
Fusions avant test ou relecture	PR #31 fusionnée avant le test sur téléphone, PR #33 avant la relecture des titres	Une PR ouverte ne coûte rien, une erreur en ligne si
Carte de l'accueil cassée	Deux toiles retirées directement sur la branche principale, sans mettre à jour l'accueil	Tout passe par une PR, sauf le dépôt de photos
Pull request d'ajout en double (erreur de Claude)	Une PR touchant le dossier d'ajout a relancé le workflow alors que des photos attendaient	Faire attendre le workflow quand une PR d'ajout est déjà ouverte (à faire)
`robots.txt` citait les dossiers internes (erreur de Claude)	Un commentaire écrit pour expliquer, dans un fichier public	Corrigé par la PR #52 : un fichier public ne décrit jamais l'intérieur du site
Google montrait encore l'ancien site	`www` et l'adresse principale servaient la même page en `200` depuis le début	Une adresse, une page : la redirection `301` ordonne, la balise `canonical` suggère (PR #54)
Trois constats faux dans la revue de code (erreur de Claude)	Une commande qui n'affichait qu'une partie d'un fichier, des caractères comptés en octets, un choix pris pour une erreur	Vérifier un constat avant de le corriger
Une faille du formulaire classée « élevée » sans mesure (erreur de Claude)	Déduite d'un schéma de l'architecture, pas d'une mesure	Ma mesure l'a infirmée, et a révélé un autre point, corrigé dans la PR #64
Deux modifications du formulaire faites directement sur la branche principale (7 octobre)	Une correction rapide dans l'éditeur de GitHub, hors pull request	La règle vaut aussi pour moi. La protection de branche n'existe pas pour un dépôt privé en offre gratuite : la discipline doit la remplacer
Le résumé de l'état du site en retard (8 octobre, erreur de Claude)	Une conversation a fait fusionner deux PR sans le tenir à jour : la conversation suivante ne l'a vu qu'en relisant le dépôt	Une règle de plus dans `CLAUDE.md` : chaque action est notée au fil de la tâche
Deux hypothèses fausses après la revue du 8 octobre (erreur de Claude)	Un mail rejeté comme spam attribué à l'authentification du domaine, au lieu du filtre de l'hébergeur ; des envois directs sur la branche principale attribués au workflow, au lieu de mes dépôts de photos	Même leçon : vérifier un constat avant de le présenter

Incident	Cause	Ce que j'en retiens
Un menu à cinq liens annoncé (12 octobre, erreur de Claude)	Les règles du projet imposent une seule ligne dès 360 px ; elles n'avaient pas été relues avant l'annonce	Un lien s'ajoute au menu en en retirant un autre : « Sous le capot » est passé dans le pied de page
Deux PR fusionnées dans une branche intermédiaire, pas dans la branche principale (12 octobre, erreur de Claude)	Pour découper le travail, Claude avait empilé les PR #73 et #74 sur la branche de la #72, que j'avais déjà fusionnée	Leur contenu n'était pas en ligne. Tout a été repris dans la PR #75, qui part de la branche principale. Des PR empilées demandent de vérifier leur cible avant de les fusionner
Mise à jour de ce document écrite au mauvais endroit (12 octobre, erreur de Claude)	Claude a modifié directement le texte publié, sans passer par la source du retex ni par ses contrôles	Un contrôle ne vaut que si on passe par lui. La PR a été fermée et la mise à jour refaite par la source ; la règle est dans la feuille de route de `CLAUDE.md`, corrigée par la PR #78
Une promesse de la page de mentions légales plus ferme que le code (13 octobre, erreur de Claude)	Un texte de vie privée écrit sans être relu face au code	Une page de vie privée est une promesse : chaque phrase se vérifie dans le code. Textes corrigés par la PR #79

Réflexes cyber appliqués

Réflexe	Dans ce projet
Moindre privilège	Hébergeur relié à un seul dépôt ; workflow en deux jobs : la machine qui ouvre les photos n'a jamais le jeton d'écriture, permissions vides par défaut
Zéro confiance	Le second job contrôle le travail du premier avant de publier : fichiers autorisés seulement, ni lien symbolique ni exécutable
Sécurité de la chaîne d'approvisionnement	Actions figées par empreinte, modules vérifiés par empreinte, mises à jour relues avant fusion ; bibliothèque d'envoi de mails suivie par un fichier de verrouillage
Gestion des changements	Une branche et une PR par sujet, relue par un humain ; 79 PR en seize jours
Validation des entrées, tout ou rien	Le workflow refuse tout dépôt douteux sans rien modifier, liens symboliques compris
Limiter les fuites d'information	`robots.txt` et commentaires publics sans détails internes ; version de PHP masquée ; page « Sous le capot » en principes, jamais en réglages
Minimisation des données	Métadonnées des photos retirées (téléphone, date, GPS) ; photos brutes inaccessibles depuis le web ; polices servies localement ; journal de test vidé de mes adresses IP
Pseudonymisation	Adresses des visiteurs jamais gardées en clair : empreintes à clé secrète, effacées quand elles ne servent plus

Réflexe	Dans ce projet
Mesurer avant de conclure	La faille supposée du formulaire, infirmée par une mesure (journal temporaire, `ifconfig.me`) avant toute correction
Défense en profondeur	Politique de sécurité du contenu, en-têtes de sécurité, code tiers et fichiers internes bloqués, page par défaut supprimée
Défaillance sûre	Protections serveur hors des blocs `<IfModule>` : une panne se voit au lieu de laisser fuir. Galerie illisible : le mur se masque ; formulaire arrêté si sa configuration est incomplète
Penser à la détection	`403` gardé sur les dossiers internes : une tentative de reconnaissance reste lisible dans les journaux
Changement prudent	HSTS par paliers : 60 secondes, puis une semaine, avec vérification en ligne à chaque étape
Secrets hors du dépôt	Identifiants du formulaire hors de la racine web et hors du dépôt, lui-même privé
Tester avant la production	Règles serveur testées sur un Apache local, y compris avec un module coupé ; workflow testé sur une branche jetable
Lire les en-têtes HTTP	`curl -I` pour vérifier une mise en ligne, suivre une redirection, repérer le CDN de l'hébergeur et mesurer son temps de réponse
Transparence	Usage de l'IA affiché sur le site ; erreurs de l'IA listées ici comme les autres
Divulgation coordonnée	Un fichier `security.txt` (RFC 9116) et une section de « Sous le capot » disent comment signaler une faille
Sortie sûre	Un message de visiteur est affiché comme du texte, jamais comme du code : un script collé dans le livre d'or ne s'exécute pas (testé dans un navigateur)
Obligations légales et vie privée	Mentions légales d'un éditeur non professionnel sous pseudonyme ; pour chaque donnée, sa finalité, son fondement, son destinataire, sa conservation limitée et les droits des visiteurs ; aucun cookie ni traceur donc pas de bandeau
Dire ce que fait le code	Chaque promesse de vie privée relue contre le code avant publication ; texte corrigé quand le code ne la tient pas (PR #79)

La suite

- **Toiles noires sur Android** jusqu'au premier défilement : mesurer sur l'appareil (débogage USB, onglet Réseau) avant tout nouveau correctif.
- **Poids des pages** : sur un écran haute définition, la miniature de 640 px est trop petite et la galerie charge les images complètes, près de 28 Mo pour 62 œuvres. Il faut une taille intermédiaire. L'accueil, lui, charge toutes les miniatures pour son mur (5,6 Mo) : il faut en limiter le nombre.
- **Tenir la durée de conservation annoncée** : trier régulièrement ma messagerie.

- **Authentification des mails** : publier SPF, DKIM et DMARC, pour que personne ne puisse envoyer de faux mails au nom du domaine.
- **Descriptions obligatoires** : une vérification automatique qui signale une toile sans vraie description dans une pull request.
- **Relier ce dossier au code** : le site renvoie déjà ici, depuis sa page « Sous le capot ». Le dépôt du site reste privé : des extraits choisis et relus à la main, jamais de copie automatique d'un dépôt à l'autre.
- **HSTS** : un mois, puis un an, après vérification à chaque palier.
- **Le livre d'or, en ligne** : tester un vrai message de bout en bout, puis ajouter une vérification automatique du fichier des messages dans les pull requests (JSON valide, longueurs, pas de lien). Je l'attaquerai moi-même, en exercice : injection de script, envois en masse, champs trop longs. Une seconde version avec administration ne viendrait qu'avec une vraie protection (authentification, requêtes forgées, limite de tentatives).
- **Retirer une toile par un workflow que j'écrirai moi-même en Python**, sur les règles du workflow d'ajout : validation en tout ou rien, pull request, jeton d'écriture réservé à la dernière étape.
- **Le reste** : ménage des branches obsolètes.

Me contacter : par le formulaire du site.

Annexe : les 79 pull requests

PR	Date	Sujet	Résultat
#1	28/09	Renomme peinture1.jpg en envie.jpg	fusionnée
#2	28/09	Renomme les peintures 2 à 10 d'après leur titre	fusionnée
#3	28/09	Supprime la barre de défilement de la page d'accueil	fusionnée
#4	28/09	Adapte l'accueil et le menu aux petits écrans	fusionnée
#5	30/09	Ajoute un CLAUDE.md	fusionnée
#6	02/10	Corrige la galerie sur mobile et sous le menu	fusionnée
#7	02/10	Remplace les photos par des versions optimisées	fusionnée
#8	02/10	Supprime la page par défaut de l'hébergeur	fusionnée
#9	02/10	Sécurise le dossier du code tiers et le formulaire de contact	fusionnée
#10	02/10	Nettoie la feuille de style et le script	fusionnée
#11	02/10	Fait du logo un lien vers l'accueil	fusionnée
#12	02/10	Ajoute un workflow qui publie les peintures déposées dans un dossier de dépôt	fusionnée
#13	02/10	Ajoute la peinture « Grafity »	fusionnée
#14	02/10	Affiche le titre des peintures au survol et dans la lightbox	fusionnée
#15	03/10	Ajoute 4 peintures	fusionnée
#16	03/10	Mélange l'ordre des peintures à chaque visite	fusionnée
#17	03/10	Affiche la galerie sur deux colonnes sur téléphone	fusionnée
#18	—	Corrige les dimensions de quatre peintures dans la galerie	fermée sans fusion
#19	03/10	Remplace « Artiste Peintre » par « Street art & technoculture » dans l'en-tête	fusionnée
#20	03/10	Ajoute 4 peintures	fusionnée
#21	03/10	Retire les quatre anciennes lignes de la galerie aux mauvaises dimensions	fusionnée
#22	03/10	Ajoute les séries à la galerie et au workflow d'ajout	fusionnée
#23	03/10	Range Vivre-Mourir dans Lettres et Essai dans Électrons libres	fusionnée
#24	03/10	Refait l'accueil : mur de toiles, séries, zoom et bio (fusion 1)	fusionnée
#25	03/10	Raconte l'histoire d'Arbre de vie dans le zoom de l'accueil	fusionnée
#26	03/10	Retire les prénoms et resserre le texte du zoom sur Arbre de vie	fusionnée
#27	03/10	Crédite Claude dans le pied de page de l'accueil	fusionnée
#28	03/10	Ajoute 3 peintures	fusionnée
#29	03/10	Accélère le chargement de la galerie avec des miniatures	fusionnée
#30	03/10	Accélère l'affichage de la galerie sur téléphone	fusionnée
#31	03/10	Place les peintures de la galerie sans animation	fusionnée
#32	03/10	Ajoute 6 peintures	fusionnée
#33	03/10	Ajoute 9 peintures	fusionnée
#34	03/10	Ajoute la peinture « Space »	fusionnée
#35	03/10	Retire une toile et en renomme une autre, faute d'accord des personnes représentées	fusionnée
#36	03/10	Intègre les textes validés du site	fusionnée

PR	Date	Sujet	Résultat
#37	05/10	Héberge les polices sur le site au lieu de Google Fonts	fusionnée
#38	05/10	Rend la galerie et le formulaire accessibles, et corrige le lien piégé	fusionnée
#39	05/10	Ajoute une politique de sécurité du contenu et masque la version de PHP	fusionnée
#40	05/10	Oblige le navigateur à rester en HTTPS (HSTS), d'abord pour 60 secondes	fusionnée
#41	—	Ajoute la peinture « Essai workflow »	fermée sans fusion
#42	05/10	Sécurise le workflow d'ajout et garde le profil couleur des photos	fusionnée
#43	05/10	Ajoute 6 peintures	fusionnée
#44	—	Ajoute 6 peintures	fermée sans fusion
#45	—	Workflow: Bump the actions group with 2 updates (Dependabot)	fermée sans fusion
#46	05/10	Ajoute 19 peintures et remplace la photo de Taï Ji	fusionnée
#47	05/10	Remplace la photo de Forum et vide le dossier de dépôt des photos déjà en ligne	fusionnée
#48	05/10	Ajoute le remplacement automatique d'une peinture	fusionnée
#49	05/10	Workflow: Bump the actions group with 2 updates (Dependabot)	fusionnée
#50	05/10	Ajoute l'aperçu de partage et les bases du référencement	fusionnée
#51	05/10	Passe l'aperçu de partage à une composition symétrique	fusionnée
#52	06/10	Retire le commentaire de robots.txt	fusionnée
#53	06/10	Retire des commentaires publics les indices sur l'intérieur du site	fusionnée
#54	06/10	Redirige www vers le domaine principal, HSTS une semaine, page 404	fusionnée
#55	06/10	Remplace « peintre autodidacte » par « street art » dans les descriptions	fusionnée
#56	06/10	Sort les règles du .htaccess des blocs IfModule (défaillance sûre)	fusionnée
#57	—	Ajoute la peinture « Essai deux jobs » et remplace la photo de « Taï Ji »	fermée sans fusion
#58	06/10	Workflow en deux jobs, liens symboliques refusés, suivi du code tiers	fusionnée
#59	06/10	Garde « figuration libre » dans les textes (règle dans CLAUDE.md)	fusionnée
#60	06/10	Ajoute 1 peinture	fusionnée
#61	06/10	Ajoute 3 peintures	fusionnée
#62	06/10	Ajoute la peinture « fresque-1 »	fusionnée
#63	06/10	Ajoute la peinture « fresque-2 »	fusionnée
#64	07/10	Protège le formulaire : clé secrète, origine et configuration	fusionnée
#65	07/10	Ajoute 3 peintures	fusionnée
#66	07/10	Ajoute la peinture « Château »	fusionnée
#67	08/10	Décrit dix peintures et corrige cinq titres	fusionnée
#68	08/10	Ajoute le pied de page au portfolio et à la page À propos	fusionnée
#69	08/10	Ajoute la page « Sous le capot » et security.txt	fusionnée
#70	08/10	Ajoute Sous le capot au menu et le lien vers le retour d'expérience	fusionnée
#71	08/10	Ajoute la règle de suivi : état du site et retour d'expérience	fusionnée

PR	Date	Sujet	Résultat
#72	12/10	Ajoute le livre d'or (modération a priori) et factorise le code des formulaires	fusionnée
#73	12/10	Lie « sécurise » de la bio à Sous le capot	fusionnée dans une branche intermédiaire, reprise dans la #75
#74	12/10	Ajoute les mentions légales	fusionnée dans une branche intermédiaire, reprise dans la #75
#75	12/10	Livre d'or : messages avant le formulaire, lien de bio, mentions légales	fusionnée
#76	12/10	Précise les mentions légales	fusionnée
#77	12/10	CLAUDE.md : état du site en fin de session, feuille de route du retex, pièges de session	fusionnée
#78	13/10	CLAUDE.md : corrige la feuille de route de ce document	fusionnée
#79	13/10	Mentions légales : conservation, fondements, droits et promesses sur les adresses des visiteurs	fusionnée